Question 2: Describe Security for Cloud Computing including security for IaaS, PaaS, SaaS, and Data Security.

Cloud computing delivers computing resources over the internet using a shared, on-demand model. Its defining features include multitenancy (multiple customers sharing the same physical resources), massive scalability, elasticity, pay-as-you-go pricing and self-provisioning of resources. Services are delivered through three models, often called the SPI framework: Software as a Service (SaaS), where customers rent hosted software on a subscription basis; Platform as a Service (PaaS), where developers get a ready-made environment to build and deploy applications; and Infrastructure as a Service (IaaS), where customers get raw computing power, storage and virtual machines. These can be deployed in public clouds (operated by a third-party vendor), or hybrid clouds (where sensitive workloads stay private and less critical ones go to the public cloud). While these models bring significant cost savings and flexibility, they also introduce new security challenges because the organization no longer has full control over where its data and applications reside.

Security at the Infrastructure Level

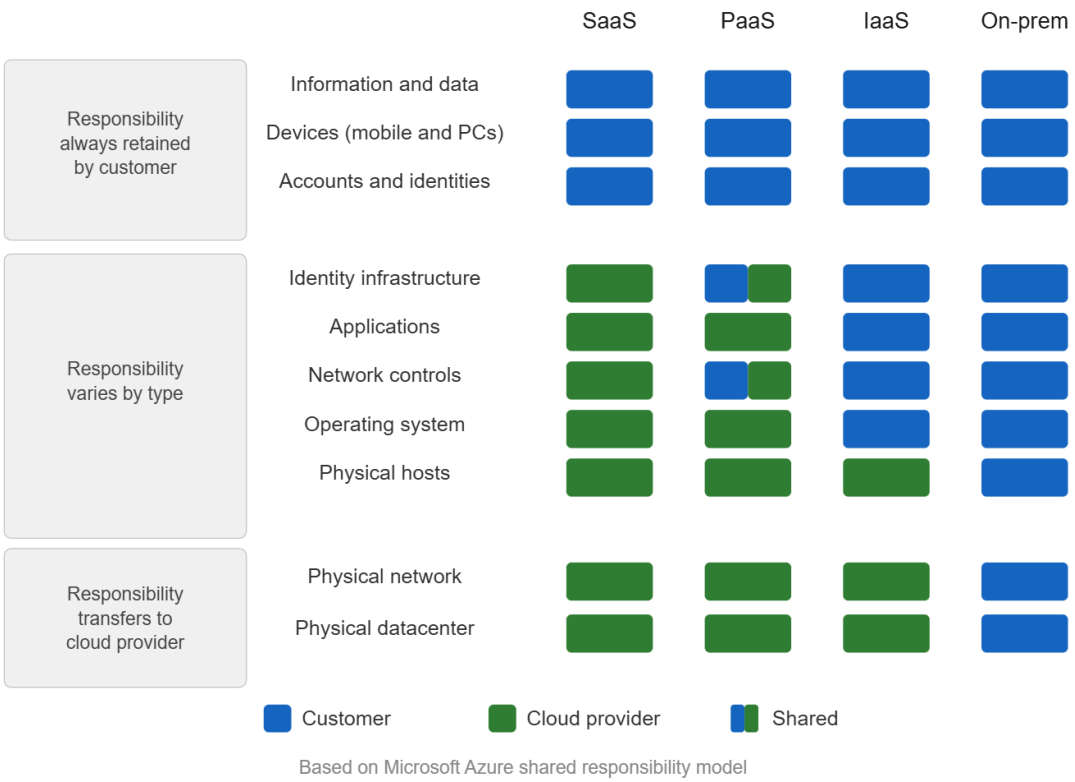
Cloud infrastructure security can be examined at three levels: network, host, and application. At each level the distribution of security responsibility between the CSP and the customer varies depending on the service model: IaaS, PaaS, and SaaS.

At the network level, the primary concerns are ensuring the confidentiality and integrity of data as it travels between the organization and the cloud, enforcing proper access control (authentication, authorization, and auditing) for cloud resources, and maintaining the availability of internet-facing services. Traditional network security relied on physical zones and tiers, but in the cloud, these are replaced by logical domains. Organizations must carefully consider how to mitigate risks such as data interception in transit, unauthorized access to cloud endpoints, and denial-of-service attacks.

At the host level, security varies significantly across service models. In Saas and Pass, the host operating system is hidden from end users, so host security responsibilities are largely transferred to the CSP. In IaaS, however, the customer is responsible for securing the guest operating system on their virtual machines. This includes patching, configuration hardening, and protecting against attach like the Blue Pill attack, which targets the hypervisor layer to inject malicious code below the operating system. Securing virtualization software, especially the hypervisor, is critical because a compromise at the level could affect all virtual machines running on the same physical host.

At the application level, security is generally a shared responsibility. In SaaS, the provider is responsible for securing the application it delivers. In PaaS, both the platform itself and the customer's applications deployed on it need to be secured. In IaaS, the customer's applications are treated as a black box by the provider, meaning the customer bears full responsibility for application-level security.

The diagram below illustrates how security responsibility shifts across these three service models:



Data Security in the Cloud

Data security is one of the most critical aspects of cloud computing because organizations are entrusting their information to a third party. Data must be protected in three states: in transit (as it moves between the organization and the cloud), rest (while stored on the provider's servers), and during processing (when the data is actively being used in a multitenant environment). Additional concerns include data lineage (tracking where data came from and how it has been transformed), data provenance (the history of data ownership and custody), and data remanence (ensuring deleted data is truly erased and cannot be recovered).

Encryption is the primary tool for protecting data in transit and at rest. However, there is a fundamental challenge: while data can be encrypted during storage and transmission, most cloud applications need to decrypt during processing, meaning the cloud will hold unencrypted data at some point. This creates a window of vulnerability. One mitigation strategy is to keep highly sensitive data out of the public cloud entirely. A future solution may be homomorphic encryption, which allows computation on encrypted data without ever decrypting it, but this technology is not yet practical for widespread use. Other solutions include strong identity and access management, key management practices, and data sanitization procedures. The core goals of data security in the cloud remain the same as in traditional IT: maintaining confidentiality, integrity, and availability.

Identity and Access Management (IAM)

In traditional environments, the trust boundary sits within the organization's control. In the cloud, this boundary becomes dynamic, extending into the service provider's domain. Identity federation has emerged as the industry's best practice for handling these loosely coupled trust relationships. IAM in the

cloud includes user management (managing the lifecycle of identities), authentication (verifying who someone is), authorization (controlling what they can do, often using standards like XACML), access management, monitoring, auditing, and compliance management. Standards like SAML enable single sign-on across cloud services, while OAuth allows one cloud service to access data in another without exposing user credentials. Cloud authorization management often relies on XACML as the preferred policy language, and role-based access control (RBAC) is also being explored for cloud environments.

Security Management, Privacy, and Compliance

Security management in the cloud follows established standards such as ITIL and ISO 27001/27002. Key areas include availability management (ensuring cloud services remain accessible according to the SLA), access control management, and vulnerability/patch/configuration management. Each of these must be adapted for the cloud context, where the CSP and the customer share responsibilities differently depending on the service model.

Privacy is another major concern. The organization that originally collected personal information remains accountable for it, even when that data is stored in a third-party cloud. While liability can be transferred through contracts, accountability cannot. Privacy risk management involves principles such as collection limitation, use limitation, retention and destruction policies, and transfer controls. Organizations must also comply with regulations such as HIPAA, FISMA, the EU Directive on Data Protection, and the Sarbanes-Oxley Act, which all have implications for how data is handled in the cloud.

Finally, auditing and compliance ensure that cloud operations meet both internal policies and external regulatory requirements. The Cloud Security Alliance (CSA) has published guidance covering 15 domains of cloud security, from architecture and risk management to application security and virtualization. Audit frameworks like SAS 70, ISO 27001 certification, and SysTrust provide structured approaches for verifying that cloud environments meet security standards.

Reference: Diagram is based on the Shared Responsibility Model from Microsoft Azure.
https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility

---

Question 3: Describe how ABAC may be implemented in an organization

Access control has evolved from simple methods like Access Control Lists (ACLs), which grant access based on user identity, to Role-Based Access Control (RBAC), which assigns permissions to roles. Both have limitations: ACLs become unmanageable at scale, and RBAC relies on static roles that are hard to update when requirements change. In fact, both are really special cases of a broader model. ACLs use one attribute (identity), and RBAC uses one attribute (role). Attribute-Based Access Control (ABAC) generalizes this idea by allowing access decisions based on any number of attributes evaluated together.

What ABAC Is

As defined by NIST SP 800-162, ABAC is a logical access control method where the decision to allow or deny an operation is made by evaluating attributes of the subject (who is requesting), the object (what is being accessed), the action (what operation is requested), and optionally the environment conditions (context like time or location). These are evaluated against a set of policies; if the attribute combination satisfies a policy, access is granted.

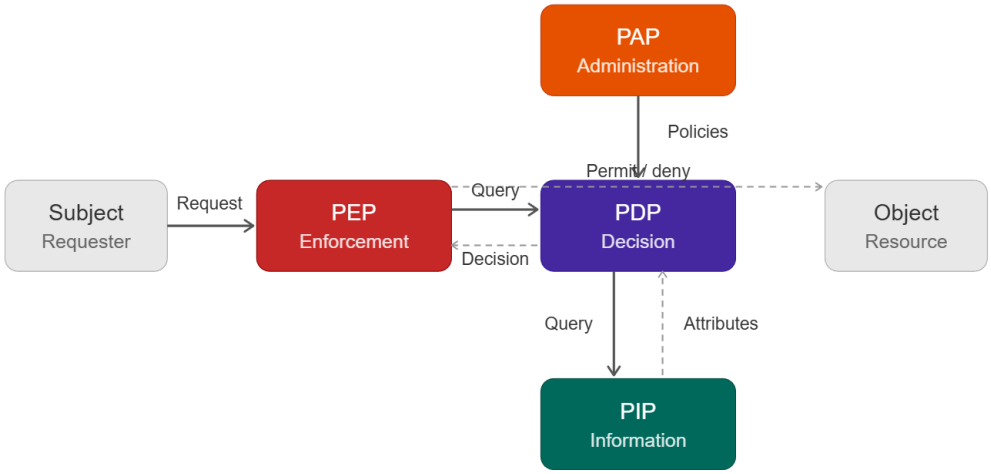
For example, in a hospital, a nurse practitioner in the Cardiology Department requests access to heart patient records. The system evaluates her subject attributes (role = Nurse Practitioner, department = Cardiology) against the object's attributes (type = Medical Records, specialty = Heart Patients) and a policy stating: "All Nurse Practitioners in Cardiology may view Heart Patient Medical Records." Access is granted. If another nurse practitioner joins Cardiology, they receive the same access automatically, without policy changes. This ability to accommodate new users without modifying policies is a key benefit of ABAC.

The Four Attribute Categories

ABAC uses four attribute types. Subject attributes describe the requester (job title, department, clearance level, citizenship). Object attributes describe the resource (sensitivity level, type, owner). Action attributes specify the requested operation (read, write, delete, execute). Environment attributes capture contextual conditions at the time of the request (date, time, network location, threat level). Policies combine these attributes using logical operations to define precise access rules.

The Access Control Mechanism

At a technical level, ABAC is implemented through an Access Control Mechanism (ACM) built from four functional components:



Based on NIST SP 800-162, Figure 5: ACM functional points

The **Policy Enforcement Point (PEP)** intercepts the user's access request and forwards it to the PDP. Once a decision is made, the PEP enforces it by allowing or blocking access. The **Policy Decision Point (PDP)** is the brain of the system. It evaluates the subject's and object's attributes against the applicable policies and produces a permit or deny decision. The **Policy Information Point (PIP)** serves as the data source, retrieving attributes from directories, HR databases, or identity systems as needed by the PDP. The **Policy**

Administration Point (PAP) is where administrators create, test, and manage the policy rules that the PDP evaluates. A Context Handler coordinates the workflow between all four components.

Implementation with XACML

The most widely used ABAC standard is the eXtensible Access Control Markup Language (XACML). XACML provides a standardized policy language for defining rules that combine attributes with Boolean logic, and a protocol for PEP-PDP communication. For example, a policy might state: "If subject's citizenship = United States AND clearance = ITAR Cleared AND department = Department 1, then permit access." XACML also supports obligations, which are mandatory actions the PEP must perform when granting access, such as logging, and advice, which are optional recommended actions.

Benefits and Deployment Considerations

ABAC is highly flexible because policies can incorporate any attribute, enabling fine-grained access control. It scales efficiently, as new users do not require changes to existing rules if they have the appropriate attributes. ABAC supports dynamic, real-time decisions that can be updated by changing attribute values rather than modifying rules. It also facilitates cross-organization information sharing through federated attributes.

However, enterprise deployment requires careful planning. Organizations must identify and standardize attributes across departments. Tagging legacy data with attributes can be operationally challenging. Policies should be thoroughly tested before deployment. Performance considerations, such as caching decisions at the PEP or attributes at the PIP, are important in high-volume environments. Despite these challenges, ABAC remains the most adaptable access control approach for modern cloud environments where traditional perimeter-based security is insufficient.

Reference: Diagram is based on NIST SP 800-162, Figure 5 – ABAC Functional Components.
https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-162.pdf

---

Question 6: Describe virtualization aspects for the Cloud

Virtualization is the simulation of software or hardware upon which other software runs. The simulated environment is called a virtual machine (VM). In cloud computing, virtualization is the foundational technology that allows cloud service providers to serve multiple customers from the same physical hardware. This answer focuses on full virtualization, where one or more complete operating systems and their applications run on top of virtual hardware, as covered in NIST SP 800-125.

Motivations for Virtualization

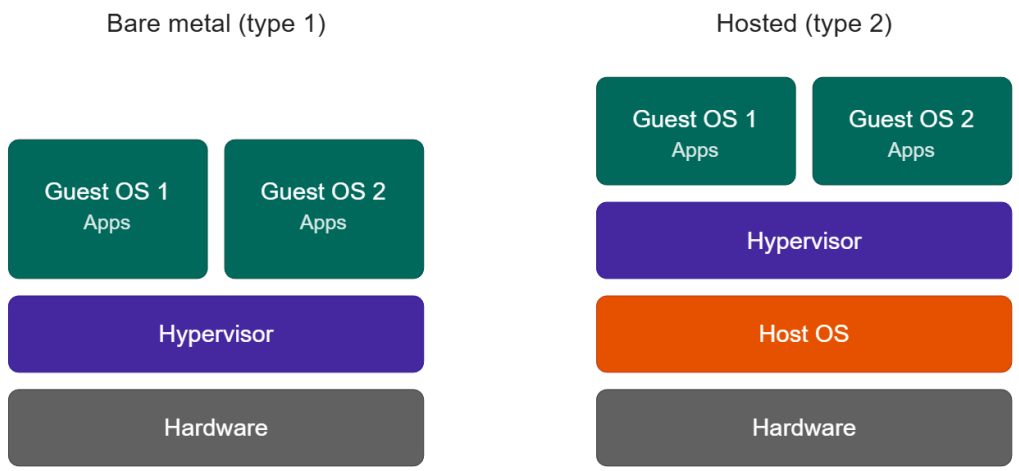
The primary driver for adopting virtualization is operational efficiency. Organizations can make much better use of their hardware by running multiple virtual machines on a single physical server, rather than dedicating one server to each service. This reduces costs related to space, power consumption, and hardware maintenance. A second major use case is desktop virtualization, where a single PC runs multiple operating systems. This is useful for running applications that require a specific OS, for testing changes

that can be rolled back safely, or for supporting legacy software on newer hardware. However, virtualization also introduces security risks: it adds technology layers that increase the management burden, consolidating systems onto one host means a single compromise can have a wider impact, and features like file sharing between VMs can become attack vectors if not controlled.

Type of Full Virtualization

There are two main architectures for full virtualizations. In bare-metal (native) virtualization, the hypervisor runs directly on the physical hardware with no host operating system beneath it. This is the architecture most commonly used for server virtualization in cloud data centers. In hosted virtualization, the hypervisor runs as an application on top of host operating systems like Windows or Linux. This is more common for desktop virtualization. The hypervisor, also called the Virtual Machine Monitor (VMM), manages the flow of instructions between guest operating systems and the physical hardware (CPU, memory, storage, network), partitions resources among VMs, and isolates each guest OS so it can only access its own resources. Choosing between bare-metal and hosted virtualization is an important security decision. A bare-metal hypervisor has small attack surface since there is no underlying OS to exploit. Adding a hosted hypervisor on top of a host OS increases complexity and potential vulnerabilities.

The diagram below shows the two architectures side by side:



Based on NIST SP 800-125, Figure 2-1: full virtualization architectures

Guest OS Isolation and Monitoring

One of the most important security properties of virtualization is guest OS isolation. The hypervisor enforces boundaries between virtual machines so that one guest OS cannot access the memory, storage, or other resources of another guest OS on the same host. This isolation is critical in cloud environments where multiple tenants share the same physical hardware. If isolation falls, a compromised VM could potentially access data belonging to another customer.

Guest OS monitoring is another key security capability. The hypervisor sits beneath the guest operating systems, which gives it a unique vantage point. It can observe and analyze the behavior of each guest OS from a position that guest OD itself cannot tamper with. This is especially valuable for legacy operating systems that lack modern security controls. The hypervisor or the host OS can add layers of authentication, auditing, and monitoring that the guest OS cannot provide on its own. However, this

monitoring must be done carefully, as it can also introduce performance overhead or create additional attack surface if the monitoring APIs are exposed.

Hypervisor Security

Securing the hypervisor is the highest priority in any virtualized environment, because a compromise at this level could give an attacker control over every virtual machine on the host. Recommended practices are keeping the hypervisor software up to date with patches, disabling unused virtual machines (such as virtual floppy drivers or serial ports), and turning off unnecessary services like clipboard sharing or file sharing between VMs. The hypervisor itself must be continuously monitored for signs of compromise. Physical access to the host hardware must also be controlled, since someone with physical access could reboot the machine and alter hypervisor security settings. Access to the virtualization management system should be restricted to authorized administrators only, and all remote administration should use encrypted communications.

Guest OS Security

Organizations should apply the same security controls to virtualized operating systems that they would apply to the same OS running directly on physical hardware. This includes regular patching, antivirus software, host-based firewalls, and secure configuration baselines. The same principle extends to applications: if a security policy exists for an application, it should be enforced regardless of whether the application runs inside a VM or on bare-metal. Additionally, virtual networking between guest OSs on the same host requires careful attention. Traffic flowing between VMs over virtual switches may not be visible to the organization's standard network monitoring tools, which creates a potential blind spot. Some organization's standard network monitoring tools, which creates a potential blind spot. Some organizations deliberately route inter-VM traffic over the physical network to maintain visibility, accepting the performance tradeoff for better security monitoring.

Reference: Diagram is based on NIST SP 800-125, Figure 2-1 – Full Virtualization Architectures.
https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-125.pdf

---

Question 9: (a) Describe Backup and Recovery for the Cloud, (b) Describe Auditing aspects for the Cloud

(a) Cloud Backup and Recovery

Cloud backup is a strategy where copies of data and applications from an organization's servers are sent to a secondary, off-site location for safekeeping. Businesses use cloud backup to ensure their files remain available if a system failure, outage, or natural disaster occurs. A third-party cloud or SaaS provider typically hosts the backup infrastructure, charging based on storage capacity, bandwidth, number of users, or frequency of data retrieval.

There are two sides to cloud backup. First, the cloud acts as a backup destination, where organizations store copies of their on-premises data. Second, the cloud itself must be backed up. All data and processes running inside the cloud need replications, and the service provider is

responsible for ensuring that cloud data centers are replicated at geographically separate locations.

Cloud backup comes with security concerns. Cloud storage services can be hacked, and they still rely on physical data centers subject to physical risks. Relying solely on cloud backups does not guarantee safety. To address these risks, providers typically offer end-to-end encryption, version history and recovery, remote access, and automatic continuously synced backups.

Cloud recovery leverages virtualization to take a fundamentally different approach to disaster recovery. Since virtualization encapsulates an entire server (operating system, applications, patches, and data) into a single software bundle, failover and fallback can happen in seconds or minutes rather than hours. Interdependent processes are restored in the correct order, to the right recovery point, and within the required timeframe. Cloud disaster recovery (cloud DR) allows enterprises to restore data to either on-premises or cloud environments, ensuring business continuity.

From a security perspective, all access control policies that apply to the original cloud environment must also be enforced on backed-up data. Backed-up systems must be protected from malware. Checkpointing can be used as a recovery technique. Recovery processes must ensure that no attacks occur during restoration and that data does not reach unauthorized parties.

(b) Cloud Auditing

Cloud auditing is the independent examination of a cloud service provider's controls, security, and performance. The main purpose is to verify that the provider meets its obligations and to make this information transparent to current and potential customers. A cloud auditor is a third party who examines these controls and expresses an opinion through a formal report.

The auditor evaluates several key areas. Security compliance is the most critical, as it can determine a company's growth and long-term viability. Assessment of management focuses on who is authorized to access services and what data they can reach, with all users actions logged for accountability. Metrics and safeguarding are evaluated together: the auditor looks at how security incidents are tracked (including failed authorization attempts), how the infrastructure is protected, and whether protections like firewalls and vulnerability scanners are continuously maintained. Penetration testing and bug bounty programs are recommended practices for validating the security infrastructure.

Beyond security, auditors also assess the reliability and integrity of the application, including whether data is processed accurately and whether the organization has a disaster recovery plan. Data retention and privacy are closely examined: the organization must define what customer information it collects, how long it maintains it, and whether deleted data is truly and permanently removed.

Question 10: Describe Mobile Cloud and the associated security issues

What is Mobile Cloud Computing?

Mobile Cloud Computing (MCC) is the approach of using cloud technology to deliver applications and services to mobile devices. Modern mobile apps perform complex tasks such as authentication, location-aware functions, and delivering targeted content, all of which require significant computational resources like storage, memory, and processing power. MCC addresses this by offloading the heavy lifting to cloud infrastructure. Instead of requiring powerful hardware on the device itself, data is stored in the cloud and computation is shifted to cloud servers, freeing mobile users from the resource constraints of their devices. Developers build and update mobile apps using cloud services and deploy them for remote access from any device.

Why MCC Matters

MCC offers several key advantages. It provides wider reach because cloud-based mobile apps are platform-independent and can run on any device and operating system. It enables real-time analytics by storing data centrally and integrating multiple data sources quickly. It improves user experience since users can access rich computational resources regardless of their device's hardware, and their data remains backed up if a device is lost. It is cost-efficient through the pay-as-you-go model, and organizations can let employees install apps on their own devices rather than purchasing specific hardware. Common use cases include social media (processing large images and videos), mobile commerce and banking, mobile gaming (running graphics-heavy games via cloud rendering), healthcare (mobile patient management), and interactive experiences like financial tickers and location-based services.

How MCC Works

MCC architecture uses four types of cloud-based resources. Distant immobile clouds are virtual servers managed by providers like AWS, where application code is deployed and requests are processed. Proximate immobile computing entities are servers located geographically closer to users to reduce latency. Proximate mobile computing entities are nearby mobile devices whose unused computational resources can be leveraged. Hybrid solutions combine all three approaches. MCC solutions come in two types: general-purpose (GPMCC), which offload compute-intensive tasks like speech recognition and image processing, and application-specific (ASMCC), which optimize specific apps like email clients or video streaming.

Security and Privacy Challenges

According to the survey by Mollah, Azad, and Vasilakos (2017) published in the Journal of Network and Computer Applications, security and privacy are the most critical challenges facing MCC. These challenges are inherited from three domains: cloud computing, mobile computing, and wireless networks. What makes MCC security particularly difficult is the combination of four factors: the insecure open-air wireless transmission medium, the resource constraints of mobile devices (which limit the complexity of security mechanisms that can run locally), distributed cloud storage and processing (where data may be spread across multiple locations), and the heterogeneity of the environment (different devices, operating systems, and network types).

The key security requirements for MCC include confidentiality (keeping mobile users' data secret in the cloud, which is challenging since data travels over public networks), integrity (ensuring data is not tampered with during transmission or storage), authentication (verifying the identity of users and devices), and availability (ensuring services remain accessible). The major security challenges span several categories. Data security concerns arise because data must be protected both in transit over wireless networks and at rest in cloud storage. Offloading security is a concern because when computation is moved from the device to the cloud, the data being offloaded must be protected during transfer. Virtualization security matters because MCC relies on cloud VMs, and a compromised VM could affect other tenants. Mobile application security involves protecting against malware that targets mobile devices, since the openness of mobile platforms attracts attackers who embed malicious code in seemingly useful applications.

On the privacy side, the main concerns include data locality (users may not know which country or jurisdiction their data is stored in), data privacy (preventing unauthorized access to personal information), and identity privacy (protecting user identities from being exposed). The survey notes that while many solutions have been proposed, including encryption, secure offloading protocols, and privacy-preserving computation techniques, open issues remain, particularly around balancing strong security with limited battery life and processing power of mobile devices.

Question 11: (a) Describe Cloud Monitoring, (b) Describe three attacks to the Cloud

(a) Cloud Monitoring

Cloud monitoring focuses on observing and securing the virtualized infrastructure that underpins cloud services. Based on the Cloud Security Alliance (CSA) white papers referenced in the lecture, the central question is where security monitoring should be placed: at the hypervisor level or at the host (guest OS) level. Each approach has distinct strengths and trade-offs.

In hypervisor-based security monitoring, the hypervisor uses a capability called introspection to look inside each virtual machine. Introspection is a set of APIs and drivers that open up each VM for inspection from the hypervisor layer. With introspection, the hypervisor can analyze the file system, programs executing in memory, and network packets entering and leaving the VM. This is powerful because it operates from a position below the guest OS, meaning even kernel-level rootkits or malware that hides from tools inside the VM can be detected. The hypervisor has a privileged view that the guest OS cannot tamper with. However, hypervisor-based monitoring has limitations in public cloud environments. Unless the cloud provider grants tenants access to hypervisor-level logging, there is no way for customers to audit introspection activity within their VM. If a provider employee goes rogue or an attacker compromises the infrastructure, introspection access to customer data could go undetected. This raises concerns about segregation of duties and trust.

In host-based security monitoring, the security tools are deployed inside the VM itself. The key advantage is portability: host-based security moves with the VM as it migrates between cloud providers or across infrastructure. It is fully controlled by the tenant, provider-agnostic, and does not require

hooks into the hypervisor. This maintains better segregation of duties. The downside is resource consumption. If multiple VMs on the same physical host all run intensive security scans simultaneously (such as full disk virus scans), performance on the host can degrade significantly, increasing costs. Newer host-based solutions designed specifically for cloud deployments address this by offloading management and computational work to the security provider's own infrastructure, reducing the CPU and memory footprint on the protected VM.

The CSA guidance recommends that organizations consider both approaches as part of a layered defense. Hypervisors should be configured to isolate VMs from each other, and internal controls should prevent unauthorized access to running VMs or volatile memory. Continuous monitoring and behavioral anomaly detection at both the hypervisor and host level are essential, since traditional network monitoring tools often cannot see traffic flowing between VMs on the same physical host.

(b) Three Attacks to the Cloud

1. Blue Pill Attack: The Blue Pill attack is a cloud-specific attack that targets the hypervisor layer. It exploits AMD's Secure Virtual machine (SVM) extensions in 64-bit processors, which allow software to manipulate processor registers, interrupts, and I/O at the hardware level. The attack manipulates kernel mode memory paging and the VMRUN instruction that controls interaction between the hypervisor and the guest VM. By doing so, it places the host operating system into its own secure virtual machine on the fly, without detection. This gives the attacker complete control over the system and allows other malware to operate undetected beneath the OS. The attack bypasses Microsoft's digital signature protection for kernel mode drivers, making it particularly dangerous.

2. Side Channel Attack: In a side channel attack, the attacker runs a VM on the same physical host as the victim's VM and exploits a shared hardware component, typically the processor cache, to steal information such as cryptographic keys. The attacker observes patterns in cache activity to infer what the victim's VM is computing. Achieving this requires the attacker to first place their VM on the same physical server as the target, which has been demonstrated to succeed in about 40% experimental trials using techniques like co-residency checks, network probes, and timing analysis. These attacks are particularly effective against IaaS clouds where VMs share the CPU's last-level cache (LLC) across cores. Some cloud providers now offer dedicated tenancy options to counter this threat.

3. Man-in-the-Cloud Attack: This is a cloud-specific attack that targets cloud synchronization tokens rather than traditional credentials. The attacker first infects the victim with malware through a malicious website or email. Once they have access to the victim's local files, they replace the cloud synchronization token with one pointing to the attacker's own cloud account, while placing the victim's original token among the files queued for synchronization. The victim unknowingly uploads their legitimate token to the attacker, who then uses it to access the victim's actual cloud data. This attack is effective because it does not require stealing passwords; it steals the authentication token itself. Malware prevention is the primary defense against this type of attack.

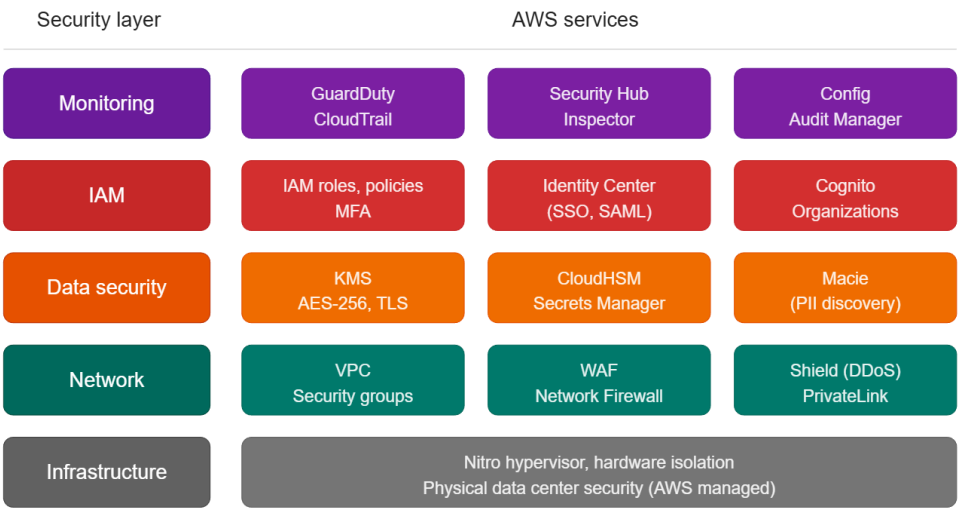
Question 12: Describe security for a cloud product (e.g., AWS, Azure)

This answer focuses on Amazon Web Services (AWS), one of the most widely used cloud platforms, and examines its security features across the key areas discussed in the lecture: identity and access management, data security, virtualization, network security, monitoring, and governance.

Shared Responsibility Model

AWS operates on a shared responsibility model that clearly divides security duties between AWS and the customer. AWS is responsible for the security "of" the cloud, meaning it secures the underlying infrastructure including physical data centers, networking hardware, and the virtualization layer (hypervisor). The customer is responsible for security "in" the cloud, which includes managing the guest operating system, configuring applications, encrypting data, and setting proper access controls. The exact split depends on the service model: with IaaS services like EC2, the customer manages more (OS patches, firewalls, application security), while with managed services, AWS takes on greater responsibly.

The diagram below maps AWS security services to the key security layers discussed in the course:



Based on AWS security services overview

Identity and Access Management (IAM)

AWS IAM is the core service for controlling who can access what resources. It supports the creation of users, groups, and roles, each with fine-grained permissions policies that follow the principle of least privilege. IAM roles allow temporary security credentials, eliminating the need to share long-term access keys. AWS also supports multi-factor authentication (MFA) for stronger verification, and IAM Identity Center (formerly AWS SSO) provides single sign-on across multiple AWS accounts and can integrate with external identity providers using SAML federation. For consumer-facing applications, Amazon Cognito handles user sign-up, sign-in, and access control. These capabilities align with the IAM standards discussed in the course (SAML, OAuth, XACML) and address the trust boundary challenges of cloud environments.

Data Security

AWS addresses data security in all three states: at rest, in transit, and during processing. For data at rest, AWS provides built-in AES-256 encryption across services like S3, RDS, and EBS. The AWS Key Management Service (KMS) centralizes cryptographic key creation, rotation, and management, and uses hardware security modules validated under FIPS 140-2. For higher assurance. AWS CloudHSM offers dedicated hardware security modules within a customer's own Virtual Private Cloud. Data in transit is protected using TLS encryption. Amazon Macle uses machine learning to automatically discover and protect sensitive data such as personally identifiable information (PII) stored in S3. These measures address the data security concerns outlined in the course, including confidentiality, integrity, availability, data lineage, and data remanence.

Virtualization and Network Security

AWS runs its EC2 instances on a custom hypervisor (Nitro), which provides strong isolation between tenants. The Nitro system minimizes the hypervisor's attack surface by offloading networking storage, and security functions to dedicated hardware, keeping the trusted computing base small, a principle emphasized in the lecture. For network, AWS Virtual Private Cloud (VPC) allows customers to create isolated network environments. Security groups act as virtual firewalls controlling inbound and outbound traffic at the instance level. AWS Network Firewall provides managed network protections for VPCs, and AWS WAF (Web Application Firewall) filters malicious web traffic. AWS Shield provides built-in DDoS protection, with the advanced tier offering real-time attack mitigation.

Monitoring, Auditing, and Compliance

AWS provides comprehensive monitoring and auditing stack. Amazon GuardDuty is a threat detection service that continuously monitors for malicious activity and anomalous behavior using machine learning. AWS CloudTrail logs all API calls across the account, providing a full audit trail for compliance and forensics. AWS Security Hub aggregates findings from GuardDuty, Inspector, Macie, and third-party tools into a single dashboard, providing a consolidated security posture view. Amazon Inspector automatically scans workloads for software vulnerabilities. AWS Config continuously monitors resource configurations against compliance rules, enabling organizations to detect drift from secure baselines. For governance, AWS Organizations enables centralized management of multiple accounts with Service Control Policies (SCPs) that enforce security guardrails across the enterprise. AWS supports compliance with over 143 security standards including PCI-DSS, HIPAA, FedRAMP, GDPR, and NIST 800-171.

Reference: Diagram is based on the AWS Security, Identity, and Compliance Service Overview:

https://docs.aws.amazon.com/whitepapers/latest/aws-overview/security-services.html

---

Question 15: Describe an Access Control Model for Big Data in the Cloud

Enforcing access control (AC) policies on Big Data (BD) systems is critical but significantly more challenging than for traditional systems. Most BD architectures have focused on handling the "three Vs"

(Volume, Velocity, Variety) while treating security as an afterthought. The result is that practical authorization for BD processing components is often not really available. The NIST paper by Hu, Grance, Ferraiolo, and Kuhn proposes a general-purpose AC scheme for distributed BD processing clusters that addresses these gaps.

The Big Data Processing Model

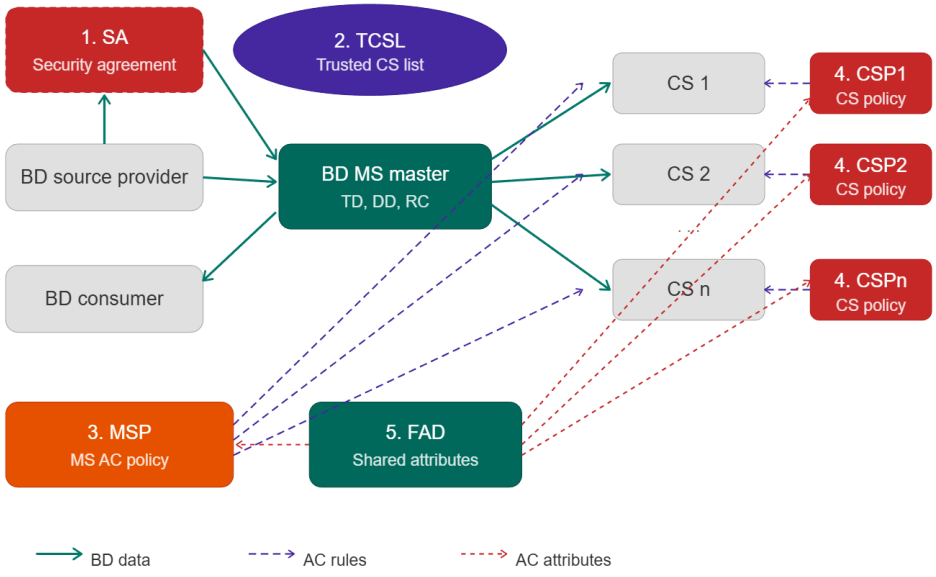
The fundamental model for BD architecture is based on distributed processing with two types of systems. The Master System (MS) receives data from BD source providers and handles user requests. It has three core functions: Task Distribution (TD), which assigns processes to cooperating systems; Data Distribution (DD), which spreads data across the cluster; The Cooperated Systems (CSs), also called slave systems, are assigned by the MS to carry out the actual BD processing, Each CS reports progress to the MS and returns computed results. Together the MS and its CSs form a BD Cluster. This model maps directly to real-world systems like Apache Hadoop, where TD corresponds to MapReduce, DD corresponds to HDFS, and CSs are the slave nodes with Task Trackers and Data Nodes.

Why Big Data Access Control is Different

BD AC is more complex than traditional AC for several reasons. Distributed computing means data is processed wherever resources are available across the MS and CSs, creating environments that are harder to secure than centralized repositories. Data fragmentation and redundancy means multiple copies of data move between the MS and CSs, complicating integrity and confidentiality. Node-to-node communication between the MS and CSs often uses insecure protocols like RPC over TCP/IP. Additionally, BD AC must not only control access to data leaving the MS but also control access to each CS's local resources, and it must synchronize access privileges between the MS and all CSs.

The Proposed Access Control Scheme

The paper proposes a scheme build from five key components that work together to enforce access control across the BD cluster:



Based on NIST BD AC paper, Figure: BD access control scheme

The Security Agreement (SA) is a mutual agreement between the BD source provider and the MS that defines security classes for the data. For example, an email log file might be classified so that only CSs with security class 1 through 3 can process it. The Trusted CS List (TCSL) is maintained by the MS and categorized each CS by security class according to the SAs. This lets the MS determine which CSs are trusted enough to receive specific data or tasks. The MS AC Policy (MSP) is managed by the MS security officer and specifies rules imposed on CSs. For instance, distributed BD data might only be readable by subjects with the attribute "company employee". The CS AC Policy (CSP) is managed by each CS's own security officer and controls access to distributed BD data and processes based on the CS's local capabilities and security requirements. For example, a CSP might forbid writing BD data to disk space shared with non-BD local users. If CSP rules conflict with MSP rules, the CSP takes priority unless otherwise agreed. The Federated Attribute Definitions (FAD) is a shared dictionary of attributes agreed upon by the MS and all CSs, ensuring that policies on both sides use the same attribute names with the same meanings.

Implementation Considerations

When deploying this scheme in a cloud environment, several additional factors arise. Trust establishment is critical: the MS may need to verify the trustworthiness of CSs using Mandatory Access Control mechanisms, with periodic updates to ensure CSs continue to meet policies. Content-based attributes become challenging at BD scale because traditional database queries may not efficiently retrieve the attributes needed for dynamic policy evaluation. AC auditing in distributed BD clusters is difficult because of interactions with files and resources which are spread across many systems, making it hard to track interconnected activity between the MS and CSs. The paper recommends implementing auditing at the infrastructure layer and adopting authentication with Mandatory AC. Cloud deployment introduces three major threats: malfunctioning infrastructure, external attacks, and insider attacks. To counter these, the scheme recommends strengthening the MSP, refining the FAD, and applying ABAC as the preferred AC model due to its flexibility in configuring and managing attributes and policies across enterprise BD systems.

Reference: Diagram is based on the BD Access Control Scheme from Hu, Grance, Ferraiolo, and Kuhn, "An Access Control Scheme for Big Data Processing," NIST.

https://csrc.nist.gov/CSRC/media/Projects/Access-Control-Policy-and-Implementation-Guides/images-media/BD%20paper.pdf